서울특별시

모바일 앱 취약점 진단 결과보고서

대상명	서울동행맵 Android

2026 년 06 월 01 일

엘앤제이테크

㈜엘앤제이테크는 본 문서에 대한 소유권을 가지며 본 문서에 담겨 있는 정보는 사전 협의 없이 어떠한 목적으로도 외부로 유출되거나 무단 복제, 무단 사용될 수 없고 기밀성을 유지한다는 전제하에 엄격하게 사용을 제한합니다.
㈜엘앤제이테크의 서면동의 없이 본 문서의 전부 또는 일부를 어떠한 수단의 형태로 복제, 복사, 배포 등을 할 수 없습니다.

목 차

1. 개요 1

가. 목적 1

나. 수행 기간 1

다. 수행 인력 1

라. 진단 대상 1

2. 수행절차 2

가. 취약점 진단 수행절차 2

나. 진단 방법 3

다. 진단 항목 3

라. 위험도 분석 5

마. 조치 시급성 5

3. 진단 결과 6

가. 진단 결과 요약 6

나. 진단 상세 결과 7

1. 개요

가. 목적

○ 본 모바일 앱 취약점 진단은 서울특별시에서 운영 중인 모바일 앱에 대해 다양한 위협 요인을 파악하고, 취약점 분석 및 대응방안을 제공함으로써 안전하고 신뢰할 수 있는 정보시스템 구축 및 운영을 위한 기반을 마련하고자 한다.

나. 수행 기간

○ 2026년 05월 21일 ~ 2026년 05월 29일

다. 수행 인력

성명	직급	담당업무
이보람	수석 컨설턴트	• 사업 관리 및 총괄
오성지	전임 컨설턴트	• 취약점 진단 수행 및 결과보고서 작성
김충겸	전임 컨설턴트	• 취약점 진단 수행 및 결과보고서 작성
김동현	전임 컨설턴트	• 취약점 진단 수행 및 결과보고서 작성
서동주	주임 컨설턴트	• 취약점 진단 수행 및 결과보고서 작성

라. 진단 대상

No	대상	OS 종류	버전	비고
1	서울동행맵	Android	2.1.8	

2. 수행절차

가. 취약점 진단 수행절차



○ 진단 환경 구축 : 모바일 앱 취약점 진단 대상 정상접속 여부, 취약점 진단 도구 동작 여부, 취약점 진단 PC의 IP 차단 예외 요청 등 사전 환경을 구축한다.

- 모바일 앱이 정상접속이 되지 않는 경우 주관기관에 보고하여 상세 사유 파악 후 진단 대상 변경 등 대책 마련

○ 계획 수립 : 취약점 진단 대상에 대한 상세 진단 일정, 취약점 진단 항목 수립 및 장애 발생 대비 공조 체계를 마련한다.

- 주관기관과의 협의를 통한 맞춤형 취약점 진단 항목 수립
- 장애 발생 시 즉시 중단하며 사전에 부여받은 공조 체계에 맞춰 담당자에게 즉시 보고 및 신속한 장애 처리를 위한 작업 내역 상세 제공

○ 취약점 진단 : 취약점 진단 도구를 활용한 모바일 앱 취약점 진단 수행 및 결과보고서를 작성한다.

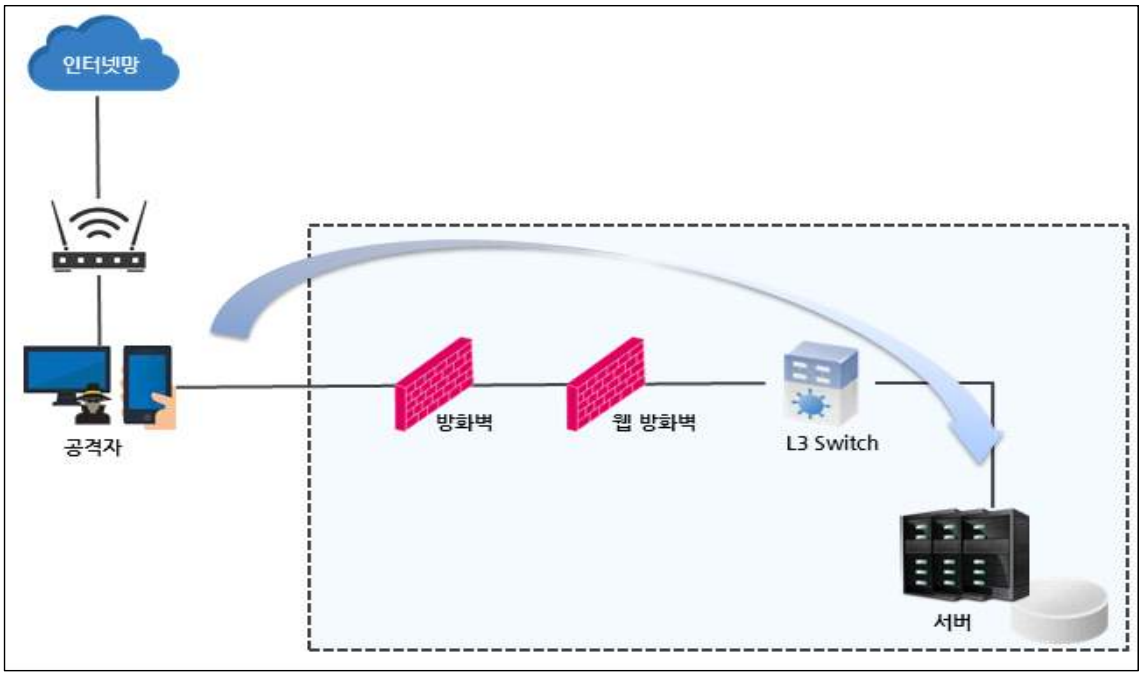
- 모바일 앱 취약점 진단은 진단 도구를 활용하여 정보수집, 정보분석, 공격 시도 단계별로 진단하며 진단 중 장애 발생 시 빠른 문제 해결을 위해 사전에 장애 복구 대책을 마련하여 업무 연속성 보장

○ 이행조치 지원 : 원활한 모바일 앱 취약점 조치를 위한 지원방안을 마련한다.

- 취약점 진단 후 작성하는 결과보고서 내 발견된 취약점 기준으로 상세 조치 내용이 포함된 이행조치 가이드 제공
- 취약점 진단 결과보고서 제공 후 이행조치 문의 응대를 위해 담당자 상시 대기

나. 진단 방법

○ 모바일 앱 취약점 진단은 아래 그림처럼 내부 또는 외부의 공격자 입장에서 대상 시스템을 진단하여 취약점을 찾고 대응책을 제시한다.



○ 진단 후 제출되는 보고서의 궁극적인 목적은 자산의 정보보호 강화를 위한 것이며, 담당자 질책의 용도로 사용되지 말아야 한다.

다. 진단 항목

○ 상위 기관 평가 항목 및 대민모바일 취약점 분석·전자금융기반시설 취약점 분석·평가 기준 항목 등을 기반으로 선별한 29개 항목이며, 상세 항목은 아래와 같다.

No	진단 항목	설명
1	정보 누출	앱 내 민감한 정보나 서비스 운영 및 서버 사이드의 구조를 파악할 수 있는 불필요한 정보 및 파일 노출 여부
2	취약한 HTTPS 암호 프로토콜 및 알고리즘	취약한 버전의 암호 프로토콜(SSL 3.0 이하, TLS 1.2 미만) 및 알고리즘(RC4 등) 사용 여부
3	중요정보의 평문 저장 및 전송	중요정보(사용자 정보, IMEI 등) 평문 전송 또는 단말기 내 평문 저장
4	메모리 내 중요정보 노출 여부	중요정보(사용자 정보, IMEI 등) 메모리 내 평문 노출 여부

No	진단 항목	설명
5	난독화	역공학 기술에 의한 모바일 앱 소스코드 유출 여부
6	백그라운드 화면 보호	백그라운드 진입 시 중요정보가 스냅샷 파일로 저장되어 노출 여부
7	앱 소스코드 내 운영정보 노출 여부	앱 소스코드 내 운영정보(개발 주소, 테스트 계정 등) 노출 여부
8	관리자페이지 노출	관리자 로그인 페이지 접근 및 계정 탈취 여부
9	불충분한 인증 및 인가	서비스 접근통제를 우회하여 비인가 메뉴 접근 등 권한 상승 가능
10	취약한 패스워드 복구	패스워드 복구 또는 변경 로직을 통해 타 계정의 패스워드 획득 및 변경 가능 여부
11	인증 정보 생성 강도 적절성	취약한 비밀번호 규칙 또는 우회 가능 여부 및 다량의 프로세스 실행 가능 여부
12	화면 강제 실행에 의한 인증단계 우회	액티비티 강제 호출을 통한 상위메뉴 강제 접근 및 중요정보 유출 가능 여부
13	비정상 동작	앱 설치 전후 비정상적인 동작 및 임의 악성 행위 기능 존재 여부
14	불필요하거나 과도한 권한 설정	불필요하거나 과도한 권한 설정으로 서비스 목적과 상이한 권한 선언 여부
15	개인정보 및 개인 위치정보 수집 및 활용에 대한 동의	사용자의 동의 없이 임의로 개인정보 및 개인위치정보를 수집하고 활용
16	디렉토리 인덱싱	하위 디렉토리 또는 파일 목록 출력 여부
17	웹 서비스 메소드 설정 공격	웹 서비스 운영상 불필요한 HTTP Method 허용 여부
18	루팅 및 탈옥 기기에서의 정상 동작	루팅 및 탈옥된 기기에서 앱 설치·동작 가능 여부
19	운영체제 명령 실행	웹페이지 내에서 운영체제 명령어 실행 가능 여부
20	SQL 인젝션	쿼리문 조작을 통해 인증 우회, DB 조회 가능 여부
21	서버 사이드 템플릿 인젝션(SSTI)	웹 서버 템플릿 엔진에 임의 코드 주입을 통한 원격 코드 실행 가능 여부
22	서버 사이드 요청 위조(SSRF)	공격자가 직접 접근할 수 없는 네트워크 대역에 대해 서버를 통한 요청 가능 여부
23	경로 추적 및 파일 다운로드	파일 호출 시 경로 조작을 통해 내부 파일 호출 가능 여부
24	파일 업로드	악성 파일 업로드 및 실행 가능 여부
25	Stored XSS	데이터 등록 구간 내 악성 스크립트 저장 및 실행 가능 여부

No	진단 항목	설명
26	Reflected XSS	데이터 조회 구간 내 악성 스크립트 전달 및 실행 가능 여부
27	불충분한 세션 만료	세션의 만료 기간 설정 여부
28	쿠키 변조	쿠키 변조를 통한 권한 상승 또는 계정 탈취 가능 여부
29	개인정보 유노출	시스템 상에 개인정보(이름, 주민등록번호, 전화번호, 주소 등)가 평문으로 외부에 노출되어 있는 취약점

라. 위험도 분석

○ 위험도 분석은 취약점의 파급력과 실제 침해 사고로 이어질 가능성을 종합적으로 고려하여 산정한다.

위험도	기준	비고
상	시스템 권한 획득, 중요 데이터 유출/변조가 즉각 가능한 치명적 결함 (예: 인증 우회, 원격 코드 실행)	
중	시스템 정보 노출, 서비스 거부 공격(DoS) 등을 유발할 수 있는 결함 (예: 디렉토리 리스팅, 중요하지 않은 권한 상승)	
하	시스템에 직접적인 피해는 적으나 보안 설정 개선이 필요한 수준 (예: 불필요한 배너 정보 노출)	

※ 위험도 산정 기준의 경우, 취약점 발생 가능성 및 영향도(시스템 환경, 노출 경로 및 연계 데이터 중요도 등)에 따라 전문가의 의견을 반영하여 각 취약점별로 위험도를 산정함

마. 조치 시급성

○ 취약점 조치는 위험도와 자산 중요도에 따라 즉각적인 대응부터 순차적 개선까지 차등 대응이 적용된다.

위험도	기준	기한	비고
즉시 조치	외부에서 인증 없이 원격 코드 실행(RCE)이 가능하거나, 관리자 권한을 획득하는 경우	발견 즉시	
단기 조치	공격자가 내부망에 접근해야 하거나, 특정 조건이 충족되어야 악용 가능한 경우	3개월 이내	
중기 조치	시스템 운영에는 영향을 주지만 실제 악용 위험이 낮거나, 일부 설계 변경 및 개발 수정이 필요한 경우	6개월 이내	
장기 조치	시스템 운영에는 영향을 주지만 실제 악용 위험이 낮거나, 근본적인 설계 변경 및 개발 수정이 필요한 경우	1~3년 이내	

3. 진단 결과

가. 진단 결과 요약

○ 서울동행맵 Android 모바일 앱에 대해 29개 진단 항목을 기준으로 취약점 진단을 수행한 결과 **총 1건이 발견되었다.**

※ 모바일 앱 취약점 진단 결과, 아래와 같은 취약점이 발견되었으나, 미 발견된 취약점이 존재할 수 있으므로 보다 안전한 모바일 앱 운영 및 관리를 위해 주기적인 취약점 진단 권고

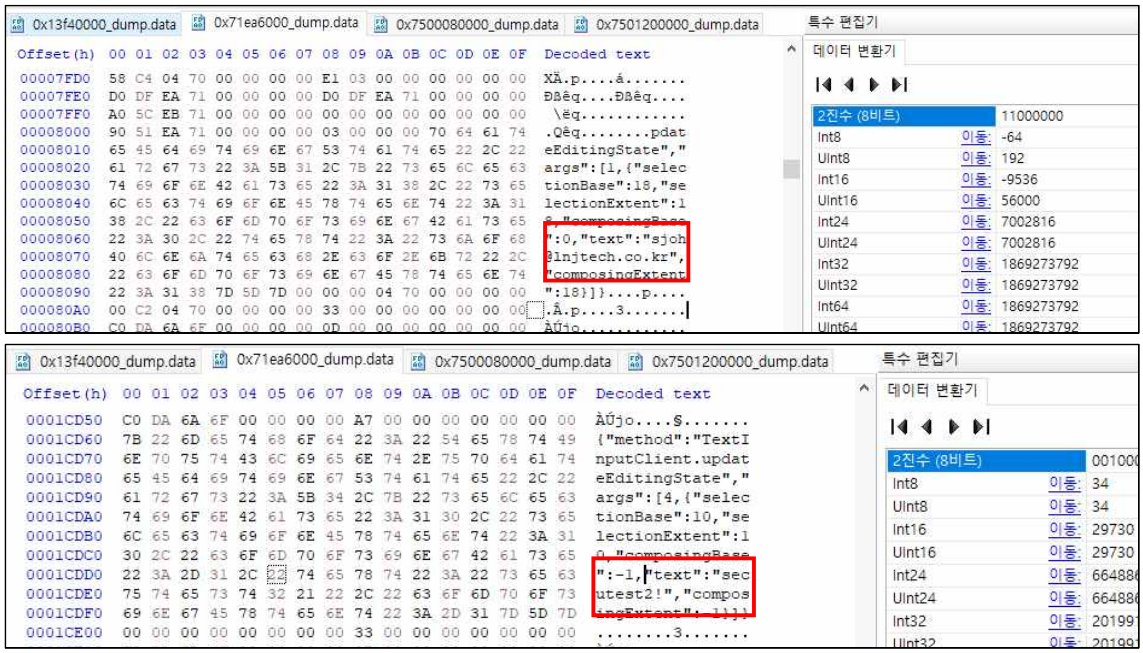
No	취약점	내용	위험도	조치 시급성
1	메모리 내 중요정보 노출 여부	메모리 내 중요정보(ID, PW)가 노출된다.	중	장기

나. 진단 상세 결과

1) 메모리 내 중요정보 노출 여부

메모리 내 중요정보 노출 여부			
위험도	하	조치기한	장기
취약위치			
URL	-		
취약점 설명			
메모리 내 중요정보(ID, PW)가 노출된다.			
상세설명			

1) 로그인 및 비밀번호 변경 기능 사용 후 메모리 덤프 시 ID, PW 정보가 노출됨을 확인



대응방안

* 중요정보 처리 시 암호화를 사용하여도 String 클래스와 같은 문자열 처리 객체에 사용되는 순간 메모리에 평문으로 적재되기에 char와 같은 자료형을 사용하여 데이터를 바이트 단위로 처리해야한다.

* 가상키패드 및 키로거 방지 등의 보안 모듈을 구현하여 이용자가 입력한 중요정보를 암호화 처리한다.

■ String, char[] 사용 예제

```
String strPassword="Unknown";
char[] charPassword= new char[]{'U','n','k','w','o','n'};
System.out.println("String password: " + strPassword);
System.out.println("Character password: " + charPassword);
```